

Secure Software Development

FINTECH 514

Spring 2021

Instructor: Jonathan Knudsen <jonathan.knudsen@duke.edu>

Course Web Site: <http://people.duke.edu/~jk471/fintech514.s21/>

Description

When software fails, either accidentally or under attack, the consequences can be severe. Creating software is incredibly easy. Creating safe, secure software is very challenging.

This course is about minimizing risk when creating software, using both an overall process as well as specific technologies. Students will learn the fundamental structure of a Secure Software Development Life Cycle (SSDLC), the advantages and challenges of cryptography, and explore automated security testing solutions.

1. *Source analysis* tools scan through source code and report on probably vulnerabilities.
2. *Supply chain* tools scan source code or binaries to build a bill of materials, a list of the software components used in building a project.
3. *Fuzzing* tools deliver deliberately malformed inputs to software to see if a failure can be triggered.
4. *IAST* tools piggyback on running Web applications to locate vulnerabilities.

Students will learn to manage risk effectively in the process of creating software.

Prerequisite

Programming experience

Learning Objectives

- Learn how a better process (Secure Software Development Life Cycle) produces better software, by enabling teams to find and fix more design, configuration, and code vulnerabilities
- Learn how cryptographic tools such as hashes and ciphers can be used to protect confidentiality and integrity
- Understand how Public Key Infrastructure (PKI) works together with Transport Layer Security (TLS) to enable commerce on the Web
- Understand and use security testing tools: (a) source code analysis, (b) software composition analysis, (c) fuzz testing, and (d) interactive application testing

Textbook

Course readings are freely available online.

Attendance

Class attendance is crucial to your success. I will not take attendance, but if you can't get to a class, it is your responsibility to catch up with the material.

Assignments

Most assignments are practical explorations based on each week's topic. In the second half of the course, the focus is on automated vulnerability hunting tools. For each type, students will install an appropriate tool and run it on a software project, both to understand the configuration of the tools as well as being able to interpret the results. As the course progresses, students will have an increasingly clear view of how to evaluate the risk profile of a software project, and an understanding of how these tools add value to the secure software development life cycle.

Assignments are posted each week after the Monday class and will be due at 12:15pm on the following Monday. **Late work is not accepted.**

Assignments must be completed individually.

Grading

60% Assignments

The lowest assignment grade is dropped; remaining assignment grades are averaged.

20% Midterm examination

20% Final examination

Topics By Week

1. **Software Security** provides an introduction to the overall topic of software security.
2. **SDLC** presents an overview of the Secure Development Life Cycle, including its motivations, advantages, and challenges.
3. **Designing Security In** presents an overview of secure design best practices and the design-time exercise of threat modeling.
4. **Cryptography 1** is an introduction to cryptography, including hashes and ciphers.
5. **Cryptography 2** expands coverage to discuss certificates and TLS.
6. **Blockchain** is an exploration of Bitcoin and Ethereum cryptocurrencies.
7. **Midterm**
8. **Supply Chain** describes the challenges of assembling modern software from components, each of which has its own vulnerabilities and its own license.
9. **Source Code Analysis** is an introduction to tools that scan source code for vulnerabilities.
10. **Fuzzing 1** introduces the concepts and execution of fuzzing.
11. **Networking** provides an introduction to the fundamentals of IP networking and using Wireshark to examine network traffic.
12. **Fuzzing 2** expands the discussion of fuzzing to discuss best practices and advanced challenges.
13. **Web Applications and IAST** explores challenges that are specific to Web applications, and the interactive automated testing that can find security vulnerabilities.

Mental Health Resources

As a student, you may experience personal or academic stress at any point throughout the semester. Duke offers several resources for students to both seek assistance on coursework and improve overall wellness, including, but not limited to:

- DuWell at (919) 681-8421 or duwell@studentaffairs.duke.edu
 - Purpose is to provide students an understanding of what wellness is and how it applies to their lives. [Moments of Mindfulness](#) programs teach practical steps that students can use, in order to facilitate the growth of their personal wellness.
- WellTrack- <https://app.welltrack.com/>
 - Offers a suite of online tools and courses that help you identify, understand and address issues that you are having. Using the variety of tracking and assessment tools and practicing mindfulness can be essential in maintaining your mental health.

The purpose of the above programming is to assist students in having a daily practice of wellness management. If your mental health concerns and/or stressful events negatively affect your daily emotional state, academic performance, or ability to participate in your daily activities, additional resources are available, including:

- DukeReach at <http://studentaffairs.duke.edu/dukereach>
 - DukeReach provides comprehensive outreach services to identify and support students in managing all aspects of their wellbeing. If you have concerns about a student's behavior or health visit the website above for resources and assistance.
- Counseling and Psychological Services (CAPS) at (919) 660-1000
 - CAPS services include: individual, group, and couples counseling services, health coaching, psychiatric services, and workshops and discussions
- Blue Devils Care at bluedevilscares.duke.edu
 - Blue Devils Care is a convenient and cost-effective way for Duke students to receive 24/7 mental health support through TalkNow.